Introduction to Cryptography

Lecture 3: OSI Security Architecture

Dr. Siddhant Thapliyal

Department of Computer Science and Engineering
Graphic Era (Deemed to be University), Dehradun

Why Do We Need a Security Architecture?

Organizations use:

- Centralized computer systems
- Local Area Networks
- Wide Area Networks
- Cloud platforms
- Mobile and IoT devices
- Distributed applications

Challenge

As systems become more interconnected, defining and managing security requirements becomes increasingly difficult.

Need for a Systematic Approach

A security manager must be able to:

- Identify security requirements.
- Understand possible attacks.
- Select appropriate security controls.
- Evaluate security products.
- Define security policies.
- Determine suitable security mechanisms.
- Assess the effectiveness of security services.

ITU-T Recommendation X.800

X.800

ITU-T Recommendation X.800 defines the Security Architecture for Open Systems Interconnection.

- Developed as an international standard.
- Provides a structured method for organizing security requirements.
- Helps vendors design compatible security features.
- Provides a common terminology for security.
- Focuses on attacks, services, and mechanisms.

OSI Security Architecture

The OSI Security Architecture organizes computer and network security into three major concepts:

1. Security attacks
2. Security services
3. Security mechanisms



Security Attack

Definition

A security attack is any action that compromises the security of information owned by an organization.

- Attempts to access information illegally
- Attempts to modify information
- Attempts to disrupt services
- Attempts to impersonate legitimate users
- Attempts to violate a security policy

Examples

Eavesdropping, replay, phishing, message modification, malware, and denial of service.

Security Mechanism

Definition

A security mechanism is a process or device designed to detect, prevent, or recover from a security attack.

- Encryption
- Hash functions
- Digital signatures
- Authentication protocols
- Access control
- Firewalls
- Intrusion detection systems
- Backup and recovery systems

Security Service

Definition

A security service is a processing or communication service that enhances the security of information systems and information transfer.

Security services:

- Counter security attacks.
- Protect data and communication.
- Use one or more security mechanisms.
- Support security policies.
- Provide confidentiality, integrity, authentication, and availability.

Attack, Service, and Mechanism

Concept	**Purpose**	**Example**
Security Attack	Attempts to violate security	Replay attack
Security Service	Protects systems and data	Authentication service
Security Mechanism	Implements protection	Digital signature

Threat and Attack

Threat

A possible danger that may exploit a vulnerability and cause harm.

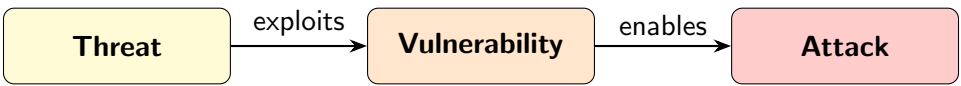
Attack

A deliberate attempt to evade security services and violate the security policy of a system.

Example

A weak password is a vulnerability. An attacker attempting to guess it is an attack. The possibility of password compromise is a threat.

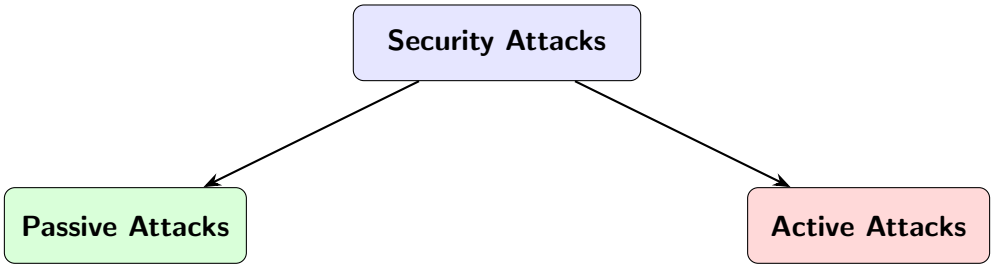
Threat, Vulnerability, and Attack



- Threat represents potential danger.
- Vulnerability represents weakness.
- Attack represents actual exploitation.

Classification of Security Attacks

Security attacks are broadly divided into:



Passive Attacks

Definition

A passive attack attempts to learn or use information from a system without affecting system resources.

- The attacker observes communication.
- The attacker does not alter the data.
- Communication continues normally.
- Sender and receiver may not detect the attacker.
- The main objective is information collection.

There are two major types of passive attacks:

1. Release of message contents
2. Traffic analysis

Release of Message Contents

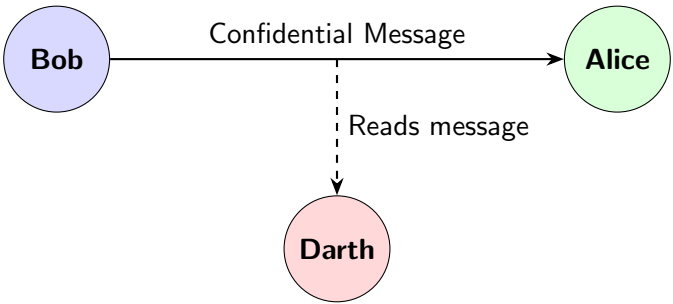
The attacker reads or intercepts confidential communication.

- Telephone conversations
- Email messages
- Files transferred over a network
- Login credentials
- Banking information
- Personal or organizational data

Security Requirement

The message contents must remain confidential even if communication is intercepted.

Release of Message Contents: Diagram



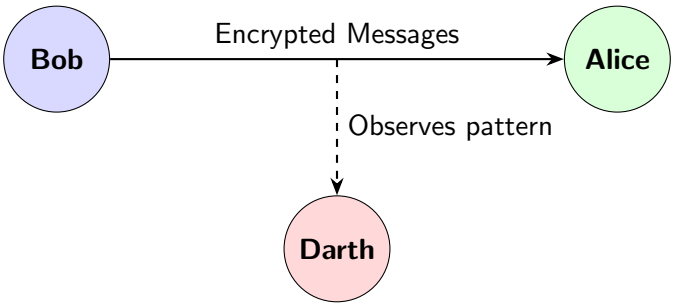
The attacker secretly reads the message sent from Bob to Alice.

Traffic Analysis

Traffic analysis occurs when an attacker studies communication patterns even when the message content is encrypted.
The attacker may observe:

- Sender and receiver identities
- Communication frequency
- Message length
- Communication timing
- Network location
- Volume of transmitted data

Traffic Analysis: Diagram



The attacker cannot read the message but observes communication patterns.

Characteristics of Passive Attacks

- Do not modify data.
- Do not directly affect system operation.
- Are difficult to detect.
- Usually target confidentiality.
- Emphasize prevention rather than recovery.
- Encryption is the main defence.

Important

Since passive attacks leave no obvious evidence, prevention is more practical than detection.

Active Attacks

Definition

An active attack attempts to alter system resources, modify communication, create false data, or affect system operation.

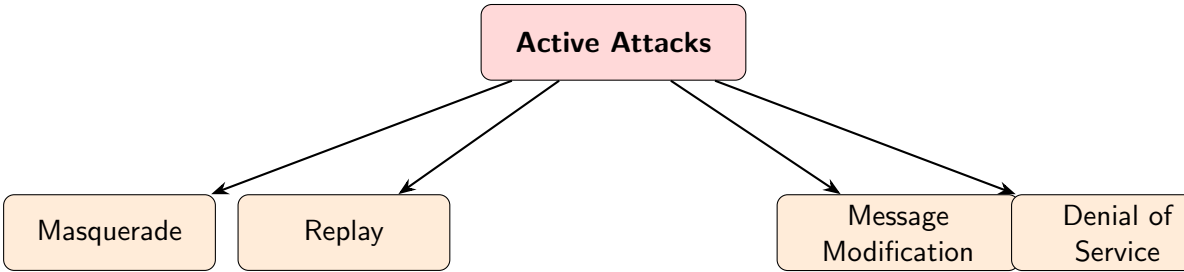
- Changes the data stream
- Creates false messages
- Disrupts communication
- Impersonates users
- Reuses previously captured messages

Types of Active Attacks

Active attacks are divided into four major categories:

1. Masquerade
2. Replay
3. Modification of messages
4. Denial of service

Active Attack Classification



Masquerade Attack

Definition

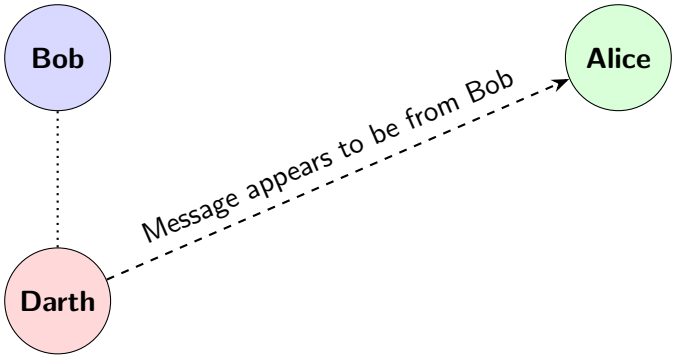
A masquerade attack occurs when one entity pretends to be another entity.

- Attacker uses stolen credentials.
- Attacker impersonates an authorized user.
- Attacker may obtain additional privileges.
- Often combined with replay or credential theft.

Example

An attacker uses a professor's password to modify student grades.

Masquerade Attack: Diagram



Darth sends a message to Alice while pretending to be Bob.

Replay Attack

Definition

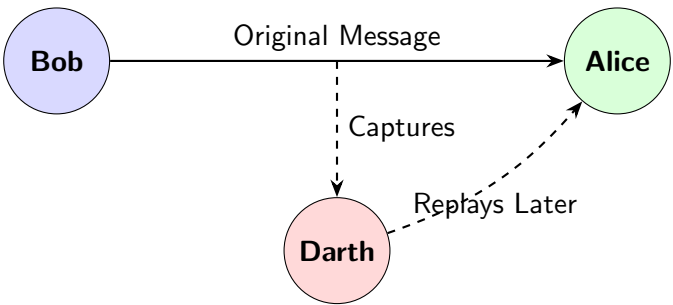
Replay involves capturing a valid data unit and retransmitting it later to produce an unauthorized effect.

- A valid message is captured.
- The message is stored by the attacker.
- It is retransmitted later.
- The receiver may accept it as fresh and valid.

Example

An attacker captures an online payment request and retransmits it to repeat the transaction.

Replay Attack: Diagram



Preventing Replay Attacks

Replay attacks can be prevented using:

- Timestamps
- Random nonces
- Sequence numbers
- Challenge-response protocols
- Session identifiers
- Short-lived authentication tokens

Freshness

The receiver must verify that the received message is fresh and has not been used before.

Modification of Messages

Definition

Message modification occurs when an attacker changes, delays, deletes, or reorders a legitimate message.

Possible actions include:

- Changing message contents
- Changing receiver information
- Delaying communication
- Reordering messages
- Deleting part of a message

Message Modification Example

Original message:

Original

Allow John Smith to read the confidential accounts file.

Modified message:

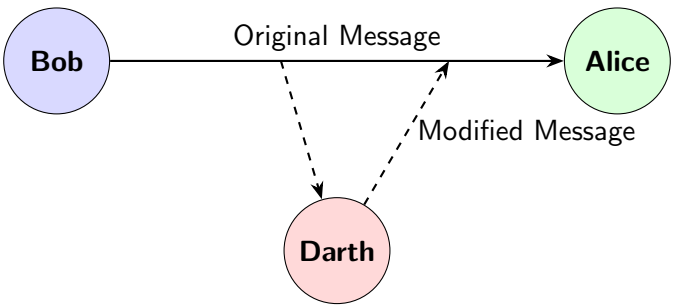
Modified

Allow Fred Brown to read the confidential accounts file.

This attack violates:

- Data integrity
- Message authenticity
- Authorization policy

Message Modification: Diagram



Denial of Service

Definition

A denial-of-service attack prevents or inhibits the normal use or management of communication facilities and services.

- Prevents authorized users from accessing services
- Overloads systems with requests
- Disables network resources
- Blocks communication
- Degrades system performance

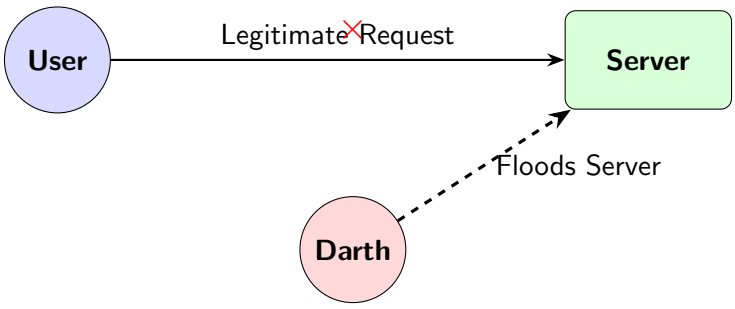
Denial of Service Examples

- Flooding a server with requests
- Disabling a network device
- Blocking messages to a destination
- Exhausting CPU, memory, or bandwidth
- Crashing a service using malformed input
- Distributed Denial of Service attack

Example

An attacker floods a university examination portal, preventing students from submitting forms.

Denial of Service: Diagram



Passive vs Active Attacks

Feature	**Passive Attack**	**Active Attack**
Objective	Obtain information	Modify or disrupt resources
Data modification	No	Yes
Detection	Difficult	Usually possible
Main security goal affected	Confidentiality	Integrity, authenticity, availability
Primary response	Prevention	Detection and recovery

Passive vs Active Attack Examples

Passive

- Eavesdropping
- Packet sniffing
- Reading email
- Traffic analysis

Active

- Masquerade
- Replay
- Message modification
- Denial of service

Handling Passive Attacks

Passive attacks are difficult to detect.
Therefore, security focuses mainly on prevention using:

- Encryption
- Secure communication channels
- Traffic padding
- Network anonymity
- Physical security
- Strong access control

Handling Active Attacks

Active attacks are difficult to prevent completely.
Therefore, security focuses on:

- Detection
- Authentication
- Integrity verification
- Intrusion detection
- Audit logging
- Recovery mechanisms
- Backup and incident response

Security Controls for Attacks

Attack	**Security Requirement**	**Control**
Release of content	Confidentiality	Encryption
Traffic analysis	Communication privacy	Traffic padding
Masquerade	Authentication	Passwords, certificates
Replay	Freshness	Nonce, timestamp
Message modification	Integrity	MAC, digital signature
Denial of service	Availability	Filtering, redundancy

Real-World Scenario

Consider an online banking application.

- An attacker reads transaction details: **Release of message contents**
- An attacker observes transaction frequency: **Traffic analysis**
- An attacker logs in as the customer: **Masquerade**
- An attacker resends a payment request: **Replay**
- An attacker changes the payment amount: **Message modification**
- An attacker makes the service unavailable: **Denial of service**

Class Activity

Identify whether each attack is passive or active:

1. Reading unencrypted Wi-Fi traffic
2. Capturing and resending an OTP message
3. Changing the destination account number
4. Observing the number of packets exchanged
5. Flooding a web server with requests
6. Logging in using another user's credentials

Class Activity Answers

1. Reading Wi-Fi traffic: **Passive**
2. Resending an OTP message: **Active – Replay**
3. Changing account number: **Active – Modification**
4. Observing packet count: **Passive – Traffic Analysis**
5. Flooding a web server: **Active – Denial of Service**
6. Using another user's credentials: **Active – Masquerade**

Quick Quiz

1. What are the three components of the OSI Security Architecture?
2. Define a security attack.
3. What is the difference between a threat and an attack?
4. Name two passive attacks.
5. Name four active attacks.
6. Why are passive attacks difficult to detect?
7. How can replay attacks be prevented?

References

- William Stallings, *Cryptography and Network Security: Principles and Practice*.
- William Stallings and Lawrie Brown, *Computer Security: Principles and Practice*.
- ITU-T Recommendation X.800, *Security Architecture for Open Systems Interconnection*.
- RFC 2828, *Internet Security Glossary*.

Thank You

Questions and Discussion